

Unifolio — Consumer-Facing MFA: Rationale and Compensating Controls

Document owner: Ahmed Al-Samak, CEO (security@unifolio.ca)

Effective date: 2026-05-13

Last reviewed: 2026-05-13

Status: Compensating-controls statement filed in response to Plaid Production Customer Agreement security questionnaire item Q4.

1. Statement

Unifolio does not currently require multi-factor authentication (MFA) for end-user sign-in to the Unifolio web application before Plaid Link is surfaced.

This document explains the architectural reasoning, the explicit compensating controls in place to mitigate the resulting authentication risk, the threat model under which we accept that residual risk, and the time-bound roadmap commitment to deploy MFA.

2. Why MFA is not yet deployed

Three reasons, in order of importance:

2.1 Stage-of-company resourcing

Unifolio is operated by a single founder (a medical student) building the product part-time. Engineering hours are spent on the highest-value risk reductions first — the choice to not yet ship MFA is a deliberate sequencing decision, not a security oversight. The full prioritization is in the technical roadmap (see §5 below). MFA is currently the next sequenced security investment after the policies, vulnerability-management, and consent infrastructure deployed in this same week (May 13, 2026).

2.2 Read-only product surface

Unifolio is a **read-only personal portfolio aggregator**. The product cannot:

- Initiate trades on any brokerage account.
- Move money in or out of any account.
- Authorize ACH/EFT transactions.
- Change beneficiary information, contact details, or account ownership at any underlying financial institution.

The blast radius of an account takeover at Unifolio is therefore **read-access to the victim's portfolio summary** — concerning from a privacy standpoint (which we treat seriously), but not financially actionable in the way a takeover at a brokerage or bank would be.

2.3 Plaid Link's own consent flow

The Plaid Link surface, when presented to a user inside Unifolio, executes Plaid's full consent and authentication flow against the underlying financial institution. That flow is governed by Plaid's own security and identity-proofing standards. A user who has compromised a Unifolio account but does not also have access to the victim's bank credentials cannot complete a Plaid Link connection in the victim's name; the bank's own login + MFA stops them at the bank's authentication step.

3. Compensating controls currently in place

The following controls reduce the likelihood, and limit the impact, of a Unifolio account-takeover attempt:

3.1 Mandatory email verification before activation

A new account is **inert** until the user clicks the verification link sent to their registered email address. They cannot:

- Connect Plaid Link
- Import broker statements
- View any portfolio data
- Persist any data to Unifolio's servers

This means an attacker would need to compromise the victim's email account before they could use a stolen or guessed Unifolio password to do anything meaningful. Email-account compromise is the same prerequisite that defeats SMS-based MFA, so the gap between "no MFA" and "MFA via the standard mechanisms" is narrower than it first appears in this product context.

3.2 Password strength enforcement and brute-force protection

Supabase Auth (Unifolio's identity provider) enforces a minimum 8-character password length at signup and password change, rejecting weaker passwords outright. Authentication attempts are rate-limited per IP and per account by Supabase's gotrue layer to defeat brute-force credential guessing. Supabase's HaveIBeenPwned breach-corpus check (Pro-tier feature) will be enabled when Unifolio upgrades from Supabase Free; HIBP enablement is on the same roadmap milestone as the consumer MFA deployment in §5 below.

Consumer MFA Rationale and Compensating Controls · Unifolio Inc. · Generated 2026-05-13 · Canonical version:
github.com/2uay/unifolio

3.3 Bcrypt password hashing with per-user salt

Passwords are stored as bcrypt hashes by Supabase Auth with the industry-standard cost factor configured by the Supabase Auth (gotrue) implementation. Even in the unlikely event of a database compromise, individual passwords cannot be recovered in any practical timeframe.

3.4 Postgres Row-Level Security on all sensitive data

Even if an attacker obtained a valid session for one user, every sensitive table in the Unifolio database has Row-Level Security policies enforcing `user_id = auth.uid()`. The attacker cannot pivot from one compromised account to another user's data. (22 RLS policies as of this writing — see `supabase/schema.sql`.)

3.5 Short-lived access tokens

Supabase Auth issues 1-hour access tokens with 7-day refresh tokens. A stolen token has limited persistence. The user can sign out from any device via Settings → Session.

3.6 No money-movement capability

Per §2.2 above, even a perfect compromise of a Unifolio account does not enable any financial action against the victim's brokerage or bank accounts.

3.7 Read-only Plaid integration

Unifolio uses Plaid only for the read-only Investments and Transactions products. We do not use Plaid Auth, Transfer, Income, or any of the money-movement-capable products. A compromised Unifolio account cannot initiate a Plaid-mediated transfer because no such code path exists in the product.

3.8 User self-service deletion

A user who suspects their account has been compromised can permanently delete all their Unifolio data in three clicks (Settings → Privacy & Data → Delete All Data) without contacting support. The database row holding any active Plaid `access_token` is hard-deleted within 24 hours; the user-facing flow prompts the user to first disconnect any Plaid Item from Settings (which calls Plaid's `/item/remove` immediately and terminates the connection at the bank end). Cascading API-side revocation on full-account-delete is a Q3 2026 roadmap item — see `DATA_RETENTION_POLICY.md` §5.

4. Threat model

We accept residual risk in the following scenarios:

Threat	Mitigation in place	Residual risk
Credential stuffing from a third-party breach	Email-verification gating + bcrypt hashing + Supabase rate-limited authentication. (HIBP breach-corpus rejection enabled when Unifolio upgrades from Supabase Free.)	Medium — partially mitigated; HIBP closes the remainder
Phishing of a Unifolio password	Email-verification gating + read-only product surface	Medium — see §5 roadmap
Brute-force guessing of a weak password	Supabase rate-limiting + 8-character password minimum	Low
Session hijacking via stolen browser token	1-hour token expiry + sign-out functionality	Low
Insider attack by Supabase / Vercel staff	Vendor SOC 2 II + DPA + no production access from Unifolio's side	Low
Account takeover leading to financial loss	Read-only product, no money movement, no trade execution	Very low
Account takeover leading to privacy breach (attacker views portfolio)	Email-verification gating	Medium — this is the primary residual risk

The "medium" residual risks above are explicitly the gap that consumer-facing MFA closes. We accept this gap in the short term given the read-only product surface (§2.2) and the email-verification floor (§3.1), and we are committed to closing it on the timeline below.

5. Roadmap commitment

Unifolio commits to deploying TOTP-based multi-factor authentication for end users by **2026-09-30**. The implementation will use Supabase Auth's built-in `auth.mfa.enroll()` flow, which supports TOTP (Google Authenticator, Authy, 1Password) out of the box. The deployment will:

1. Be **opt-in for all existing users** for a 30-day transition window.
2. Become **opt-out (i.e., enrollment prompted at next sign-in)** after the 30-day window.
3. Become **mandatory before first Plaid Link** for all new accounts created after the transition window.

After this deployment, Q4 of the Plaid security questionnaire will be re-answered as: **"Yes — Non-phishing-resistant multi-factor authentication is performed"** (TOTP is non-phishing-resistant per

current industry consensus; the subsequent step on the roadmap is WebAuthn / passkeys, targeting 2027.)

We will notify Plaid of the deployment when complete and revise this rationale document accordingly.

6. Review cadence

This rationale is reviewed:

- **Quarterly** until consumer-facing MFA is deployed.
 - **Immediately** if Unifolio adds any product capability that introduces money-movement risk (e.g., portfolio rebalancing actions, ACH-backed payments) — in which case MFA deployment is treated as a hard prerequisite to the product launch.
 - **At the time of the actual MFA deployment**, after which this document is updated to reflect the new posture.
-

Acknowledgement

— Ahmed Al-Samak, CEO, Unifolio Inc.
2026-05-13